

Rails Health Audit — example-unhealthy-project

Generated 2026-06-23 15:01. Phase 1 (static scan). Full raw tool output is in `raw_original_result/`.

1. Overview (every check, most severe first)

Priority	Category	Tool	Finding	Raw output
🔴 1	Security	brakeman	4 warning(s)	<code>raw_original_result/brakeman.txt</code>
🔴 1	Security	bundler-audit	8 vulnerable advisory(ies)	<code>raw_original_result/bundler-audit.txt</code>
🔴 1	Compliance	license_finder	73	<code>raw_original_result/license_finder.txt</code>
🟡 3	Performance	fasterer	5 speed suggestion(s)	<code>raw_original_result/fasterer.txt</code>
🟡 4	Maintainability	rubycritic	score 95.48, 31 smell(s)	<code>raw_original_result/rubycritic.txt</code>
🟡 4	Rails conventions	rails_best_practices	19 warning(s)	<code>raw_original_result/rails_best_practices.txt</code>
⚪ 4	Maintainability	rubocop	27 offense(s)	<code>raw_original_result/rubocop.txt</code>
⚪ 4	Maintainability	erb_lint	8 ERB offense(s)	<code>raw_original_result/erb_lint.txt</code>
⚪ 5	Tech debt	bundle outdated	2	<code>raw_original_result/outdated.txt</code>

Legend — 🔴 must fix (security / data) · 🟡 should fix (correctness / maintainability) · ⚪ nice to have (style / freshness).

A  **skipped check is NOT a pass.** It means the tool could not run in this environment, not that there is nothing wrong. `license_finder` needs a real `bundle install`; `bundle outdated` needs the project's own Ruby (this run used a different Ruby than the project pins). Re-run both in the project's environment to get a real result. *(In this example both ran — it is a real, bundle-installed Rails 8 app — so neither is skipped.)*

2. Action plan

How to read this — cut noise with confidence/criticality: static tools over-report. brakeman tags each warning High / Medium / Weak confidence — fix the **High** ones first; Weak ones are often false positives. bundler-audit tags each advisory Critical / High / Medium — triage **Critical/High**, don't treat all 100+ as equal. So a raw count (e.g. "137 advisories") is a starting point, not 137 separate jobs.

Severity first. Cover every  and  finding (one row each); collapse the  style-level findings into a single row. Use `<br>` for line breaks inside a cell.

#	Pr i	Issue (tool, file:line)	Solution	Ef fo rt	Raw
1		Command injection (brakeman, High) <code>app/controllers/products_c ontroller.rb:28 — system ("convert #{thumb} ...")</code> shells out with user input.	Never interpolate params into a shell. Use an image library (<code>im age_processing / vips</code>) or pass args as an array so no shell is invoked.	M	<code>raw_origin al_result/b rakeman.tx t</code>
2		SQL injection (brakeman, High) <code>app/controllers/products_c ontroller.rb:8 (where("... # {params[:q]} ...")) and :10 (connection.execute with interpolation).</code>	Parameterize: <code>where("name LI KE ?", "%#{q}%")</code> ; <code>whitelist p arams[:sort]</code> against allowed columns.	M	<code>raw_origin al_result/b rakeman.tx t</code>
3		XSS (brakeman, High) <code>app/views/products/index.h</code>	Drop <code>.html_safe</code> ; let Rails auto-escape. If HTML is	S	<code>raw_origin al_result/b</code>

#	Pr i	Issue (tool, file:line)	Solution	Eff ort	Raw
		tml.erb:4 — params[:q].html_safe renders raw user input.	needed, sanitize an allow-list.		rakeman.txt
4	●	Vulnerable gem: jwt 2.3.0 (bundler-audit, High) CVE-2026-45363 — empty-key HMAC signature bypass.	Upgrade gem "jwt", ">= 3.2.0", then bundle update jwt.	S	raw_origin al_result/b undler-audi t.txt
5	●	Vulnerable gem: rexml 3.2.4 (bundler-audit, 7 advisories incl. High ReDoS GHSA-2rxp-v6pw-ch6m).	Upgrade gem "rexml", ">= 3.3.9", then bundle update rexml. One bump clears all 7.	S	raw_origin al_result/b undler-audi t.txt
6	●	License compliance (license_finder) 73 dependencies have no approval decision.	Set an allowed-license policy; approve/replace anything copyleft (GPL) that conflicts with the product license.	M	raw_origin al_result/l icense_find er.txt
7	●	Data integrity (active_record_doctor — runtime) 2 missing foreign keys (products.owner_id , tags.product_id); 2 columns need NOT NULL; products.sku needs a unique index.	Add migrations: add_foreign_key , change_column_null , add_index ... unique: true . See the Phase 2 report.	M	raw_origin al_result/p ass2_ar_doc tor.txt
8	●	rescue Exception (rails_best_practices) app/controllers/products_controller.rb:35 swallows every error, incl. signals.	Rescue StandardError (or a specific class) and re-raise / report the rest.	S	raw_origin al_result/r ails_best_p ractices.tx t
9	●	Fat controller / logic in view (rails_best_practices) products_controller.rb:14, 41 (@product used >4x) and index.html.erb:13 .	Move create/update body into a service or model method; move the view conditional into a model helper.	M	raw_origin al_result/r ails_best_p ractices.tx t

#	Pr i	Issue (tool, file:line)	Solution	Eff ort	Raw
10	●	Missing indexes (lol_dba — runtime) 2 association columns (owner_id , product_id) have no index.	add_index on each foreign-key column; pairs with the FK work in row 7.	S	raw_origin al_result/p ass2_lol_db a.txt
11	●	Maintainability smells (rubycritic, 31) app/models/product.rb — Law of Demeter (owner.address.city), feature envy, complex #s .	Add delegations (delegate :city, to: :address); rename/extract #s ; de-duplicate the create / update blocks.	M	raw_origin al_result/r ubycritic.t xt
12	●	Slow Ruby idioms (fasterer, 5) app/models/report.rb:6 (select{}.first → detect), :16 (reverse.each → reverse_each); plus config/* .	Swap to the faster idiom each line names — trivial, mechanical.	S	raw_origin al_result/f asterer.tx t
13	●	Style (rubocop 27 + erb_lint 8) spacing, tag formatting, layout across app/ .	Auto-fix: rubocop -A and erb_lint --autocorrect , then commit the diff.	S	raw_origin al_result/r ubocop.txt raw_origin al_result/e rb_lint.tx t

3. Phase 2 — runtime checks (need app + DB)

For this example the app boots against its SQLite DB, so Phase 2 **ran** — see [dynamic-scan-report.md](#) in this folder. Results (folded into rows 7 and 10 above):

- **Data correctness** — active_record_doctor : 2 missing FKs, 2 missing NOT NULL, 1 missing unique index
- **Missing indexes** — lol_dba : 2 unindexed association columns

Still manual (need the app *exercised*, not just booted):

- **N+1 queries** — `bullet` (dev/test) or `prosopite` ; exercise app / run tests — note the per-row `product.owner` lookup in `index.html.erb`
- **Test coverage** — `simplecov` → run the suite, read `coverage/index.html`